



LAPORAN

Eksplorasi Security Misconfiguration

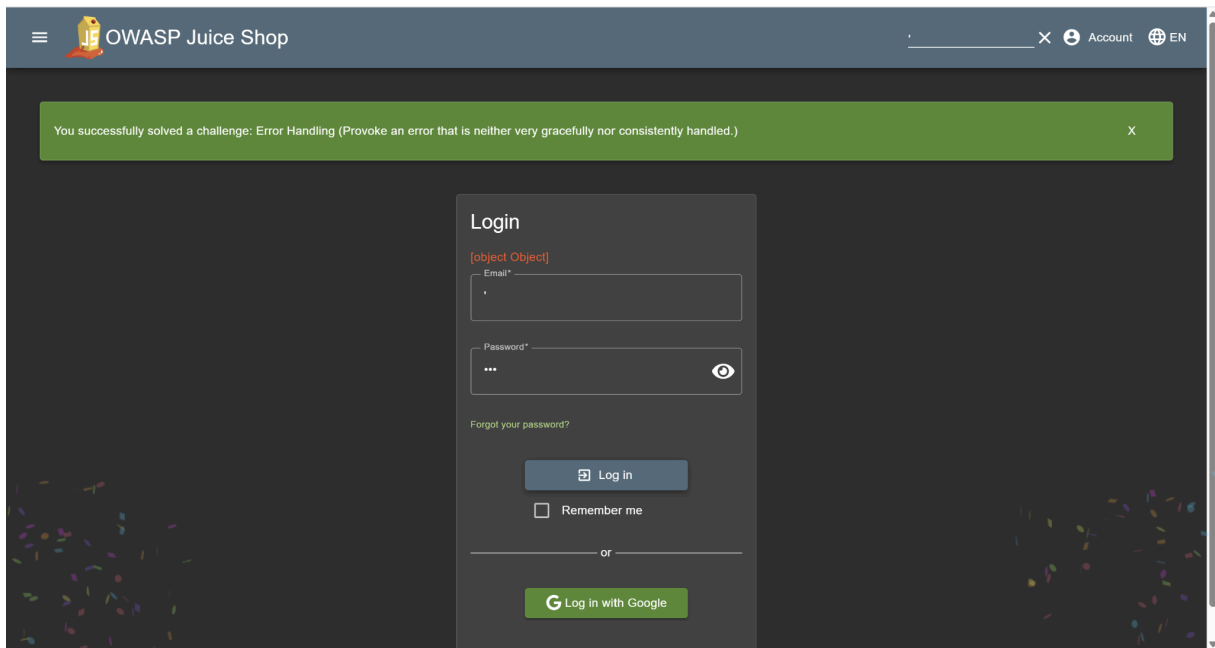
Bootcamp Cyber Security Batch 6

Disusun oleh: Ligar Alfath Rizqi

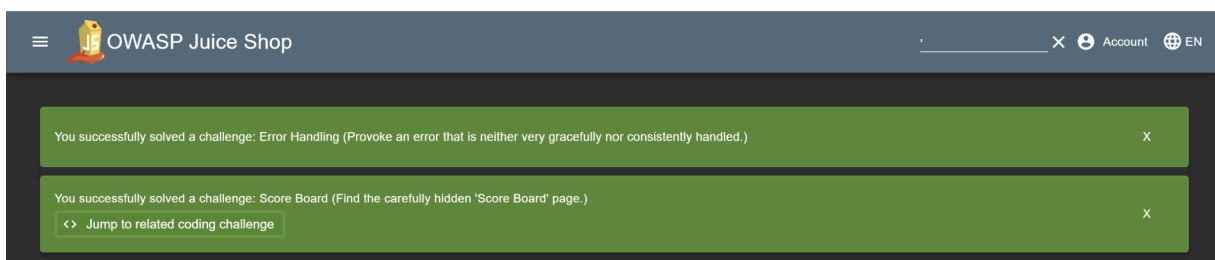
Mei 2026

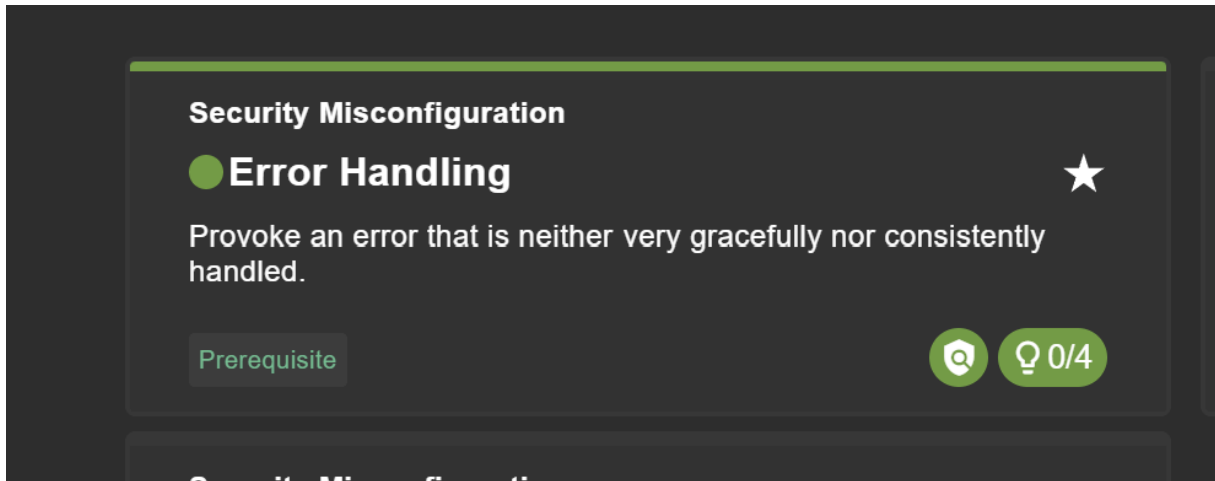
I. Error Handling: Memprovokasi sistem dengan input anomali agar menghasilkan pesan error yang tidak ditangani dengan baik, sehingga membocorkan detail kerangka kerja (seperti stack trace file).

Memasukkan payload ' dan password bebas



Challenge Solved





Kerentanan terjadi karena aplikasi tidak memiliki mekanisme error handling yang baik. Ketika menerima input anomali, backend menghasilkan object error internal yang langsung ditampilkan ke user tanpa sanitasi atau formatting yang aman.

Error tersebut menunjukkan bahwa:

- validasi input kurang baik
- exception handling tidak proper
- aplikasi membocorkan informasi internal

Mitigasi

1. Gunakan Generic Error Message

Aplikasi sebaiknya hanya menampilkan pesan umum seperti:

Invalid email or password

2. Implementasikan Centralized Error Handling

Contoh:

```
app.use((err, req, res, next) => {  
  res.status(500).send("Internal Server Error")  
})
```

3. Validasi dan Sanitasi Input

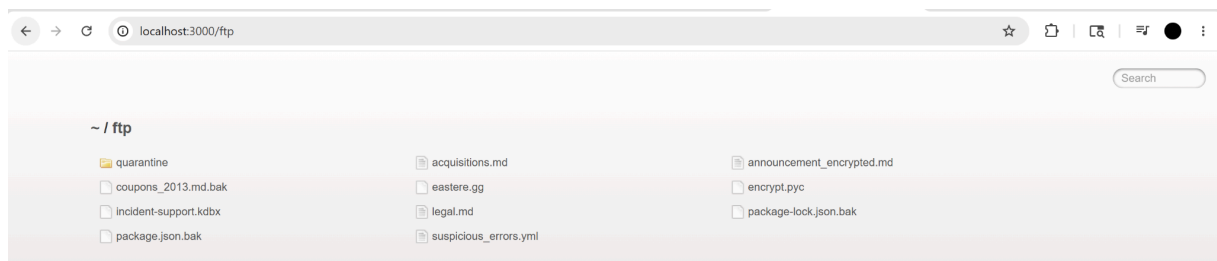
Semua input user harus divalidasi sebelum diproses backend.

4. Nonaktifkan Verbose Error

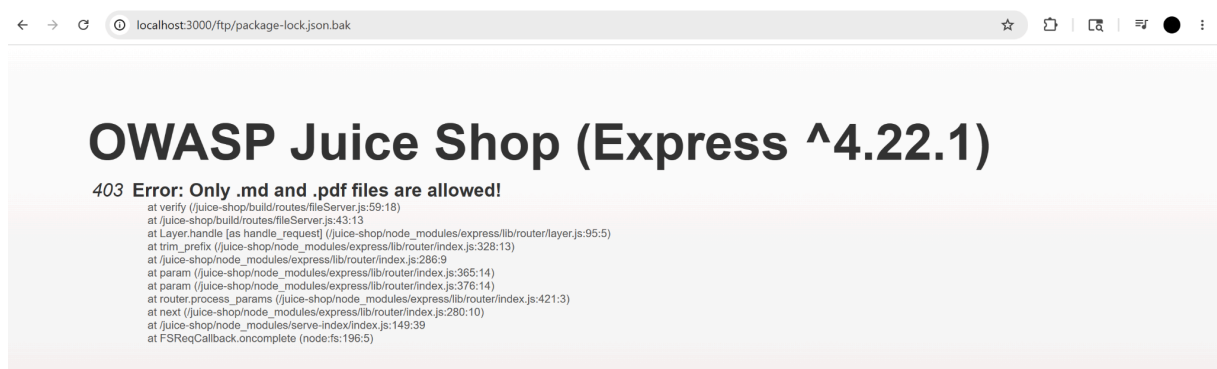
Error internal dan object backend tidak boleh ditampilkan ke user pada production environment.

II. Forgotten Sales Backup: Mencari celah daftar direktori (directory listing) terbuka dan mengunduh berkas cadangan milik tim penjualan yang secara tidak sengaja dapat diakses oleh publik tanpa otentikasi.

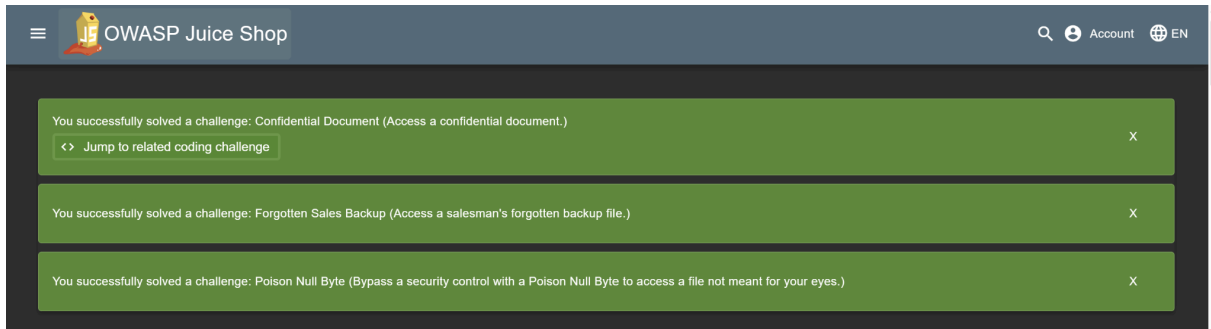
Mengakses endpoint /ftp



Bukan file backup



Challenge solved



Kerentanan terjadi karena:

- server mengaktifkan directory listing
- file backup sensitif disimpan pada public directory
- validasi file hanya berdasarkan extension
- tidak ada authentication/access control

Strategi Mitigasi

1. Disable Directory Listing

Apache

Options -Indexes

Nginx

autoindex off;

2. Jangan Simpan Backup di Public Directory

SALAH:

/var/www/html/backup/

BENAR:

/opt/internal-backup/

3. Gunakan Validasi File yang Aman

Jangan hanya memvalidasi extension filename.

Gunakan:



- MIME type validation
- whitelist path
- secure file handling library